

Módulo 2: Vulnerabilidades de Inyección

T05: Cross-Site Scripting (XSS)

Carlos Rodríguez Contreras · GitHub: karrocon

 *Injectar JavaScript en el navegador del usuario — y robar su sesión*

Objetivos

- Distinguir XSS reflejado, almacenado y basado en DOM
- Explotar el campo de comentarios de VulnApp (XSS almacenado)
- Demostrar el robo de cookies de sesión mediante XSS
- Implementar CSP y sanitización de output como defensa

En construcción

Este topic todavía no tiene slides completas.

Usa las diapositivas maestras (`slides-curso.html`) como referencia del contenido previsto.

Lab T05: XSS Almacenado en comentarios

Objetivo: inyectar un script que robe la cookie de otro usuario

Setup: `cd VulnApp && npm start` → `http://localhost:3000/comments`

1. Publica un comentario con `<script>alert(document.cookie)</script>`
2. Observa que el script se ejecuta al ver los comentarios
3. Abre `src/routes/comments.ts` y añade sanitización de HTML
4. Verifica que el payload aparece como texto, no se ejecuta